

DSGVO-Checkliste zur Rollen- und Zugriffskontrolle ****Projekt:** Zero-Trust-Sicherheitskonzept mit GitHub-Integration** ****Erstellt:** 15.10.2026** ****Prüfer:** Daniel Massa (Prüfling), Datenschutzbeauftragter VFB** --- ## 1. Rechtmäßigkeit der Verarbeitung (Art. 6 DSGVO) | Nr. | Prüfpunkt | Status | Bemerkung | |---|---|---|---| | 1.1 | Liegt eine Rechtsgrundlage für die Verarbeitung vor? | Ja | Art. 6 Abs. 1 lit. f (berechtigtes Interesse: IT-Sicherheit, Compliance) | | 1.2 | Ist die Verarbeitung verhältnismäßig? | Ja | Nur notwendige Daten (User-ID, Name, E-Mail, Rolle) | | 1.3 | Wurde eine Interessenabwägung durchgeführt? | Ja | Dokumentiert in DPIA (Anhang) | --- ## 2. Grundsätze der Datenverarbeitung (Art. 5 DSGVO) | Nr. | Prinzip | Prüfpunkt | Status | Bemerkung | |---|---|---|---|---| | 2.1 | ****Rechtmäßigkeit, Verarbeitung nach Treu und Glauben**** | Transparente Information der Betroffenen | Ja | Datenschutzhinweis im Self-Service-Portal | | 2.2 | ****Zweckbindung**** | Daten nur für Rechtevergabe genutzt | Ja | Keine Weiterverwendung zu anderen Zwecken | | 2.3 | ****Datenminimierung**** | Nur erforderliche Daten erhoben | Ja | Keine Passwörter, keine biometrischen Daten | | 2.4 | ****Richtigkeit**** | Daten aktuell und korrekt | Ja | Synchronisation mit Azure AD (Single Source of Truth) | | 2.5 | ****Speicherbegrenzung**** | Löschkonzept definiert | Ja | Automatische Löschung nach Austritt + 30 Tage | | 2.5 | ****Integrität & Vertraulichkeit**** | Technisch-organisatorische Maßnahmen (TOMs) | Ja | TLS, Verschlüsselung, Zugriffskontrolle, Audit-Logs | --- ## 3. Rechte der betroffenen Person (Art. 12–22 DSGVO) | Nr. | Recht | Umsetzung | Status | |---|---|---|---| | 3.1 | Auskunftsrecht (Art. 15) | Export-Funktion für Audit-Logs, Self-Service-Ansicht | Umgesetzt | | 3.2 | Recht auf Berichtigung (Art. 16) | Korrektur über Azure AD / Admin-Interface | Umgesetzt | | 3.3 | Recht auf Löschung (Art. 17) | Automatisiert bei Austritt (30-Tage-Frist) | Umgesetzt | | 3.4 | Recht auf Einschränkung (Art. 18) | Deaktivierung statt Löschung möglich | Umgesetzt | | 3.5 | Recht auf Datenübertragbarkeit (Art. 20) | CSV/JSON-Export der eigenen Daten | Umgesetzt | | 3.6 | Widerspruchsrecht (Art. 21) | Nicht anwendbar (keine Direktwerbung) | N/A | --- ## 4. Technisch-organisatorische Maßnahmen (Art. 32 DSGVO) | Maßnahme | Implementierung | Status | |---|---|---| | ****Pseudonymisierung / Verschlüsselung**** | TLS 1.3 für alle Kommunikation, DB-Verschlüsselung at rest | | ****Vertraulichkeit**** | Rollenbasierte Zugriffskontrolle (RBAC), Least Privilege | | ****Integrität**** | Append-Only Audit-Logs, Hash-Verkettung, DB-Trigger gegen UPDATE/DELETE | | ****Verfügbarkeit**** | Backups, Monitoring, Incident Response Plan | | ****Resilienz**** | GitHub Actions als managed Service, DB-Replikation | | ****Verfahren zur Überprüfung**** | Regelmäßige Security-Scans (CodeQL, Dependabot), Pen-Test geplant | | --- ## 5. Datenschutz-Folgenabschätzung (Art. 35 DSGVO) | Aspekt | Bewertung | |---|---| | ****Systematische Beschreibung**** | Rechteverwaltung für 50 Mitarbeiter, cloudbasiert (GitHub), automatisierte Entscheidungen | | ****Notwendigkeit & Verhältnismäßigkeit**** | Erforderlich für IT-Sicherheit, Compliance; keine Alternative mit geringerem Eingriff | | ****Risiken**** | Unbefugter Zugriff auf Rollendaten, Fehlkonfiguration, Secret-Leakage | | ****Maßnahmen zur Risikominimierung**** | RBAC, Policy-as-Code, Secret-Scanning, 4-Augen-Prinzip, Audit-Logs | | ****Restrisiko**** | Niedrig (akzeptabel) | | ****DSB-Beteiligung**** | Durchgeführt, dokumentiert, freigegeben | | --- ## 6. Auftragsverarbeitung (Art. 28 DSGVO) | Auftragsverarbeiter | Zweck | AVV vorliegend | TOMs

geprüft | |---|---|---|---| | ****GitHub Inc. (GitHub Enterprise Cloud)**** | Hosting der Repositories,
 Actions, Teams, Audit-Logs | Ja (GitHub DPA) | SOC 2 Type II, ISO 27001 | |
****Microsoft Azure (Azure AD / Entra ID)**** | Identity Provider, SSO | Ja (Microsoft DPA) |
 ISO 27001, SOC 1/2/3 | --- ## 7. Verzeichnis von Verarbeitungstätigkeiten (Art. 30
 DSGVO) Eintrag in VVT des VFB vorhanden: ****"Automatisierte Rechteverwaltung (Zero-
 Trust-RBAC)"**** Kategorien: Beschäftigtendaten (Name, E-Mail, Rolle), Protokolldaten (Audit-
 Logs) --- ## 8. Meldung von Datenschutzverletzungen (Art. 33/34 DSGVO) - ****Prozess
 definiert:**** Ja (Incident Response Plan, Kapitel 7.4) - ****Frist:**** 72 Stunden an
 Aufsichtsbehörde (LfDI Baden-Württemberg) - ****Betroffeneninformation:**** Bei hohem Risiko
 unverzüglich --- ## 9. Datenschutzbeauftragter (Art. 37–39 DSGVO) - ****Bestellt:**** Ja (intern,
 VFB) - ****Beteiligung am Projekt:**** Ja (Interviews, DPIA-Freigabe, Abnahme) -
****Kontakt:**** dsb@vfb-bildung.de --- ## 10. Zusammenfassung & Freigabe | Prüfkriterium |
 Status | |---|---| | Rechtmäßigkeit (Art. 6) | Konform | | Grundsätze (Art. 5) | Konform | |
 Betroffenenrechte (Art. 12–22) | Konform | | TOMs (Art. 32) | Konform | | DPIA (Art. 35)
 | Durchgeführt | | AVV (Art. 28) | Vorliegend | | VVT (Art. 30) | Erfasst | | DSB (Art.
 37–39) | Beteiligt | ****Gesamtbewertung:**** Das Zero-Trust-RBAC-System ist ****DSGVO-
 konform**** ausgestaltet. Alle relevanten Anforderungen wurden technisch und organisatorisch
 umgesetzt. --- ****Unterschrift Prüfling:**** _____ ****Unterschrift DSB:****
 _____ ****Datum:**** _____ (End of file - total
 125 lines)